5. COSO and NIST Control Assessment

5.1 Internal Control Assessment Overview

The IT Security Risk Assessment incorporated internal control considerations to demonstrate how technical vulnerability findings can inform cybersecurity governance, risk management, and IT audit activities.

The 12 risks documented in the IT Security Risk Register were mapped to relevant concepts from two established frameworks:

- **COSO Internal Control—Integrated Framework:** Provides a structured approach to understanding internal controls, accountability, risk assessment, and monitoring.
- **NIST Special Publication 800-53:** Provides a catalog of security and privacy controls that organizations can use to address information system risks.

The purpose of these mappings was to identify security control objectives relevant to the vulnerabilities discovered during the assessment.

The assessment did not include formal testing of an organization's internal control design or operating effectiveness.

Accordingly, the observations in this section represent **proposed control considerations rather than formal audit findings or confirmed organizational control deficiencies**.

5.2 COSO Internal Control Framework

The COSO Internal Control Framework consists of five interconnected components.

COSO Component	Purpose	Relevance to the Assessment
Control Environment	Establishes accountability, governance, and expectations for internal control	Supports ownership of cybersecurity responsibilities
Risk Assessment	Identifies and evaluates risks that could affect organizational objectives	Supports evaluation of vulnerability-related business risks
Control Activities	Establishes policies and procedures to mitigate identified risks	Addresses authentication, configuration, patching, and access restrictions
Information and Communication	Ensures relevant information is communicated to appropriate stakeholders	Supports risk reporting, escalation, and management decisions

COSO Component	Purpose	Relevance to the Assessment
Monitoring Activities	Evaluates whether controls remain effective over time	Supports vulnerability monitoring and remediation validation

Primary COSO Component: Control Activities

The 12 registered risks were primarily mapped to **Control Activities**.

This component was selected because the identified weaknesses involved technical safeguards intended to prevent or limit unauthorized access, insecure configurations, and exploitation of vulnerable services.

Examples include:

- Restricting administrative access.
- Enforcing secure authentication requirements.
- Removing unnecessary or insecure services.
- Maintaining supported operating systems and applications.
- Implementing secure configuration standards.
- Validating vulnerability remediation.

The presence of these weaknesses on the intentionally vulnerable laboratory system illustrates why such control activities are important.

However, the assessment does not establish that an actual organization failed to design, implement, or operate these controls.

5.3 NIST SP 800-53 Control Mapping

Relevant NIST SP 800-53 controls were identified to support the documented risk treatment recommendations.

The mappings focused on five principal control areas.

Control Area	Relevant NIST Controls	Control Objective
Access Control	AC-3, AC-6, AC-17	Restrict access and enforce appropriate privileges
Identification and Authentication	IA-5	Manage authenticators securely
Configuration Management	CM-6, CM-7, CM-8	Maintain secure configurations, limit unnecessary functionality, and track system components
System and Information Integrity	SI-2	Identify and remediate system vulnerabilities and flaws

Control Area	Relevant NIST Controls	Control Objective
System and Communications Protection	SC-7, SC-8	Protect network boundaries and communications

These controls were selected because their objectives align with the security weaknesses identified during the vulnerability assessment.

The mappings are illustrative and do not represent a complete NIST SP 800-53 control baseline.

5.4 Control Consideration 1 — Access Control and Least Privilege

Relevant Risks: RISK-002, RISK-003, RISK-008, RISK-010, RISK-012

COSO Component: Control Activities

Relevant NIST Controls:

- AC-3 — Access Enforcement
- AC-6 — Least Privilege
- AC-17 — Remote Access

Assessment Observation

Several findings demonstrated or indicated the potential for unauthorized access to privileged accounts or remote execution services.

Examples included:

- Root-level command execution through the Ingreslock backdoor.
- Greenbone-reported passwordless root access through rlogin.
- Successful MySQL authentication using an empty database root password.
- Remote command execution through DistCC under a daemon account.
- Successful PostgreSQL authentication using default credentials.

These findings illustrate the potential consequences of insufficient access restrictions and excessive exposure of privileged services.

Control Objective

Access controls should ensure that users and services receive only the permissions necessary to perform authorized functions.

Privileged access should be restricted, appropriately authenticated, and monitored.

Recommended Control Activities

Organizations should establish controls to:

1. Restrict privileged access to authorized administrators.
2. Apply least-privilege principles to system and application accounts.
3. Disable unnecessary remote administration services.
4. Restrict administrative access through approved network paths.
5. Periodically review privileged accounts and access permissions.

Potential IT Audit Procedures

An IT auditor could evaluate these controls by:

- Reviewing privileged account listings.
- Inspecting access control policies and configuration standards.
- Sampling privileged access approvals.
- Examining remote access restrictions.
- Reviewing evidence of periodic access recertification.

Assessment Status: Control objectives identified; organizational control design and operating effectiveness not tested.

5.5 Control Consideration 2 — Authentication and Credential Management

Relevant Risks: RISK-003, RISK-008, RISK-011, RISK-012

COSO Component: Control Activities

Relevant NIST Control:

- IA-5 — Authenticator Management

Assessment Observation

The vulnerability assessment identified authentication weaknesses involving missing, empty, default, or easily guessed passwords.

Greenbone successfully authenticated to MySQL using an empty root password, PostgreSQL using default credentials, and VNC using a weak password.

The scanner also reported passwordless root access through rlogin.

These findings illustrate the importance of secure authenticator management.

Control Objective

Authentication controls should prevent unauthorized access by requiring appropriate credentials and protecting them throughout their lifecycle.

Recommended Control Activities

Organizations should:

1. Eliminate default and empty passwords.
2. Require strong, unique credentials for privileged accounts.
3. Use centralized identity management where appropriate.
4. Restrict access to sensitive authentication interfaces.
5. Implement periodic reviews of authentication configurations.
6. Apply multifactor authentication where supported and appropriate.

Potential IT Audit Procedures

An IT auditor could:

- Review password and authentication standards.
- Inspect account configuration samples.
- Verify that default credentials are changed before deployment.
- Review privileged account management procedures.
- Evaluate whether authentication exceptions are documented and approved.

Assessment Status: Authentication weaknesses demonstrated or reported on the laboratory target; organizational authentication controls not tested.

5.6 Control Consideration 3 — Secure Configuration and Attack Surface Reduction

Relevant Risks: RISK-001, RISK-005, RISK-007, RISK-009, RISK-010

COSO Component: Control Activities

Relevant NIST Controls:

- CM-6 — Configuration Settings
- CM-7 — Least Functionality
- SC-7 — Boundary Protection

Assessment Observation

The scan identified exposed services and application components associated with insecure configurations, remote execution, and unauthorized file disclosure.

Examples included:

- Distributed Ruby remote procedure functionality.
- The insecure rexec service.
- The vsftpd backdoor finding.
- The exposed Apache Tomcat AJP connector.
- DistCC remote command execution.

These findings demonstrate the risks associated with unnecessary services, insecure configurations, and insufficient network access restrictions.

Control Objective

Secure configuration controls should minimize unnecessary functionality and limit system exposure to authorized users and services.

Recommended Control Activities

Organizations should:

1. Establish approved secure configuration baselines.
2. Disable services that are not required for business operations.
3. Restrict administrative and application interfaces.
4. Review network firewall rules and access permissions.
5. Monitor configuration changes.
6. Periodically compare deployed systems against approved baselines.

Potential IT Audit Procedures

An IT auditor could:

- Review secure configuration standards.
- Compare sampled system settings against approved baselines.
- Examine change management records.
- Inspect firewall rules and service exposure.
- Review exception approvals for nonstandard configurations.

Assessment Status: Technical vulnerabilities identified; no formal organizational configuration compliance assessment performed.

5.7 Control Consideration 4 — Vulnerability and Patch Management

Relevant Risks: RISK-004, RISK-006, RISK-009

COSO Component: Control Activities

Relevant NIST Controls:

- SI-2 — Flaw Remediation
- CM-8 — System Component Inventory

Assessment Observation

The vulnerability assessment identified outdated application components and an unsupported operating system.

Greenbone detected:

- A vulnerable TWiki application version.
- Ubuntu 8.04, which reached end of life in 2013.
- An Apache Tomcat AJP vulnerability associated with Ghostcat.

These findings illustrate the security exposure that can arise when organizations do not maintain supported software versions or remediate known vulnerabilities.

The laboratory was intentionally configured with vulnerable software; therefore, these observations should not be interpreted as evidence that an actual organization lacks effective patch management.

Control Objective

Vulnerability and patch management controls should identify, prioritize, and remediate security weaknesses within timeframes appropriate to organizational risk.

Recommended Control Activities

Organizations should:

1. Maintain an accurate inventory of operating systems and applications.
2. Identify unsupported or end-of-life technology.
3. Conduct periodic vulnerability assessments.
4. Establish risk-based remediation priorities.
5. Track remediation activities to completion.
6. Validate corrective actions through testing or rescanning.

Potential IT Audit Procedures

An IT auditor could:

- Review vulnerability management policies.
- Examine recent vulnerability scan reports.
- Sample remediation tickets and closure evidence.
- Compare remediation dates against approved service-level requirements.
- Review exceptions involving unsupported technology.
- Evaluate whether unresolved risks are escalated appropriately.

Assessment Status: Vulnerabilities identified; no organizational patch management process or remediation effectiveness testing performed.

5.8 Control Consideration 5 — Network and Communications Protection

Relevant Risks: RISK-001, RISK-003, RISK-005, RISK-009, RISK-011

COSO Component: Control Activities

Relevant NIST Controls:

- SC-7 — Boundary Protection
- SC-8 — Transmission Confidentiality and Integrity
- AC-17 — Remote Access

Assessment Observation

The assessment identified services that could expose administrative interfaces, transmit credentials insecurely, or permit access to application resources.

Examples included:

- Legacy rlogin and rexec services.
- An exposed VNC service.
- Distributed Ruby remote procedure functionality.
- The Apache Tomcat AJP connector.

The rexec finding was particularly relevant to communications protection because the protocol lacks modern encryption protections for credentials.

Control Objective

Network and communications controls should restrict unauthorized connectivity and protect sensitive information transmitted between systems.

Recommended Control Activities

Organizations should:

1. Segment systems according to business and security requirements.
2. Restrict administrative services to approved management networks.
3. Disable insecure legacy protocols.
4. Use encrypted remote administration methods.
5. Review network access rules periodically.
6. Monitor for unauthorized service exposure.

Potential IT Audit Procedures

An IT auditor could:

- Review network segmentation standards.
- Inspect firewall and access control configurations.
- Examine approved remote access methods.
- Review evidence of periodic firewall rule assessments.
- Evaluate documented exceptions for insecure protocols.

Assessment Status: Relevant technical exposures identified; organizational network control effectiveness not tested.

5.9 Control Mapping Summary

The following table summarizes the relationship between the primary risk themes, COSO components, and relevant NIST SP 800-53 controls.

Risk Theme	Associated Risks	COSO Component	Relevant NIST Controls
Unauthorized Remote Execution	RISK-001, RISK-002, RISK-007, RISK-010	Control Activities	AC-3, AC-6, CM-7, SC-7
Weak Authentication	RISK-003, RISK-008, RISK-011, RISK-012	Control Activities	IA-5, AC-3, AC-6
Unsupported and Vulnerable Software	RISK-004, RISK-006	Control Activities	SI-2, CM-8
Insecure Remote Administration	RISK-005	Control Activities	CM-7, AC-17, SC-8
Application Connector Exposure	RISK-009	Control Activities	CM-6, CM-7, SC-7

These mappings support the assessment's proposed risk treatment recommendations.

The detailed Risk Register contains the control references associated with each individual risk.

5.10 Distinguishing Vulnerability Assessment From Control Testing

A vulnerability assessment and an IT audit may examine related security concerns, but they answer different questions.

A vulnerability assessment primarily asks:

What technical weaknesses are present on the assessed system?

An IT audit evaluates questions such as:

Has the organization designed appropriate controls, implemented them, and demonstrated that they operate effectively?

For example, discovering an empty database administrator password provides evidence of an insecure configuration on the assessed system.

However, determining whether an organization's privileged access management controls are ineffective would require additional evidence.

That evidence might include:

- Approved security policies.
- System configuration standards.
- Account provisioning procedures.
- Control ownership and accountability.
- Configuration samples across relevant systems.
- Evidence of monitoring and management review.
- Documentation of approved exceptions.

Without such evidence, the assessment cannot support a formal conclusion about enterprise control effectiveness.

This distinction is important for maintaining the accuracy and credibility of IT security risk reporting.

5.11 Overall Internal Control Assessment Conclusion

The technical findings identified several security areas where effective internal controls would be important in a production environment.

These areas include privileged access management, authentication, secure configuration, vulnerability remediation, and network protection.

The COSO Internal Control Framework provided a governance perspective, while NIST SP 800-53 supplied specific security control objectives relevant to the identified risks.

The resulting mappings demonstrate how technical vulnerability findings can inform internal control discussions, risk treatment planning, and potential IT audit procedures.

However, **no formal organizational control design or operating effectiveness testing was performed**.

Therefore, this section does not express an audit opinion or conclude that any production organization's internal controls are deficient.

The next section presents the recommended risk treatment actions and proposed remediation priorities.